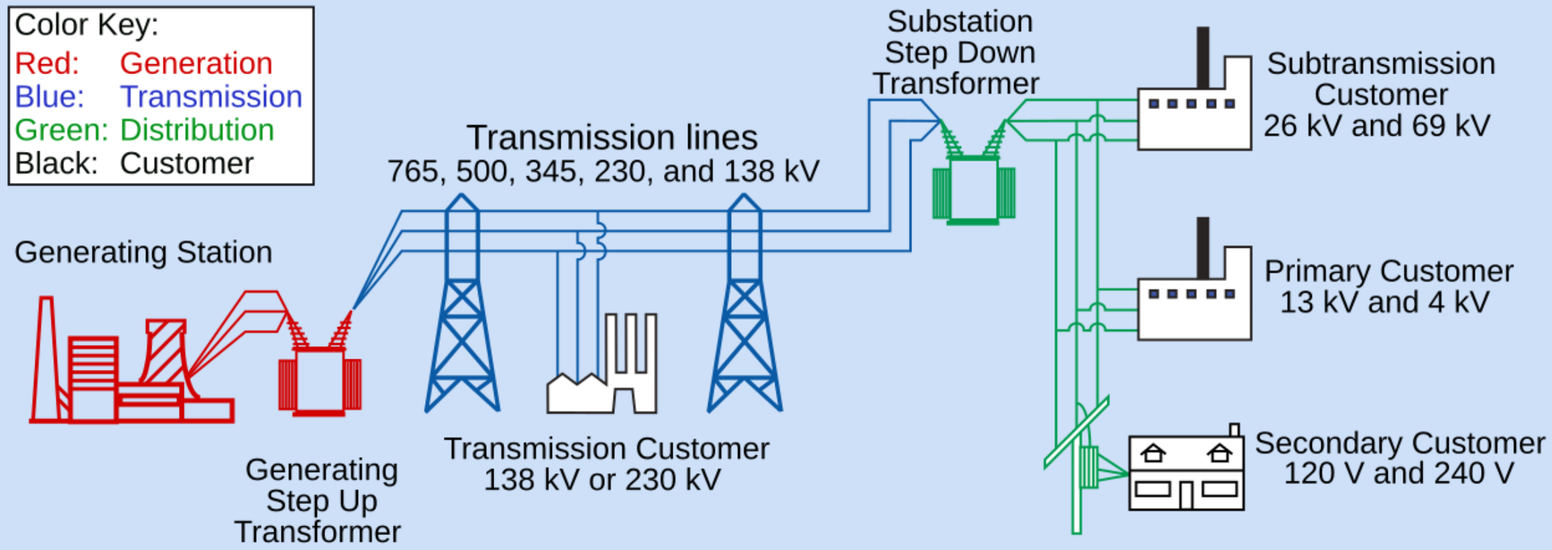
CYBERSECURITY FOR SMART GRIDS

Analysis of Cyberattack happened in Ukraine in 2015

Presented by Aditya Salunke

Inside a Power Grid: Generation, Wires, and the Flow of Energy



SMART GRIDS

They represent advanced cyber-physical systems that integrate the cyber realm with traditional grid infrastructures. i.e integrating OT with IT.

Bidirectional

Non-centralised

Intelligent

Key Features

- Real-time monitoring of use and supply
- Two-way sharing of power and data
- Works smoothly with renewable sources
- Boosts reliability, sustainability, and efficiency

WHY CONVERGE IT WITH OT ?

1. Modern enterprises and utility operators aim to utilize their OT assets.
2. Advanced ICT integration allows bidirectional data and power flow among IoT, microgrids, and DERs, enabling real-time control and predictive grid management via cloud-native platforms.
3. This integration leads to significant economic optimization and technological standardization.
4. Technology such as neural networks can help detect early blackouts and failures.

What are ICS?

ICS refers to Industrial Control System. ICSs are integral part of Critical infrastructure and have been utilised to supervise industrial machines and processes.
They perform :

- **Real time monitoring and interacting with devices.**
- **Real time collection and analysis of data.**
- **Logging of all events happening in industrial systems.**

What is SCADA?

Supervisory Control and data acquisition

SCADA is the largest subset of ICS. It provides GUI through it's HMI. HMI makes it easy to observe status of the system and interact with the IIoT devices and detect abnormal behaviour. These systems consist of four different subsystems :

- **I/O Network**
- **Supervisory control**
- **Control Network**
- **Corporate Network**

I/O Network

It consits of deployed IIoT devices(sensors and actuators etc) in the industrial process.

Supervisory Control

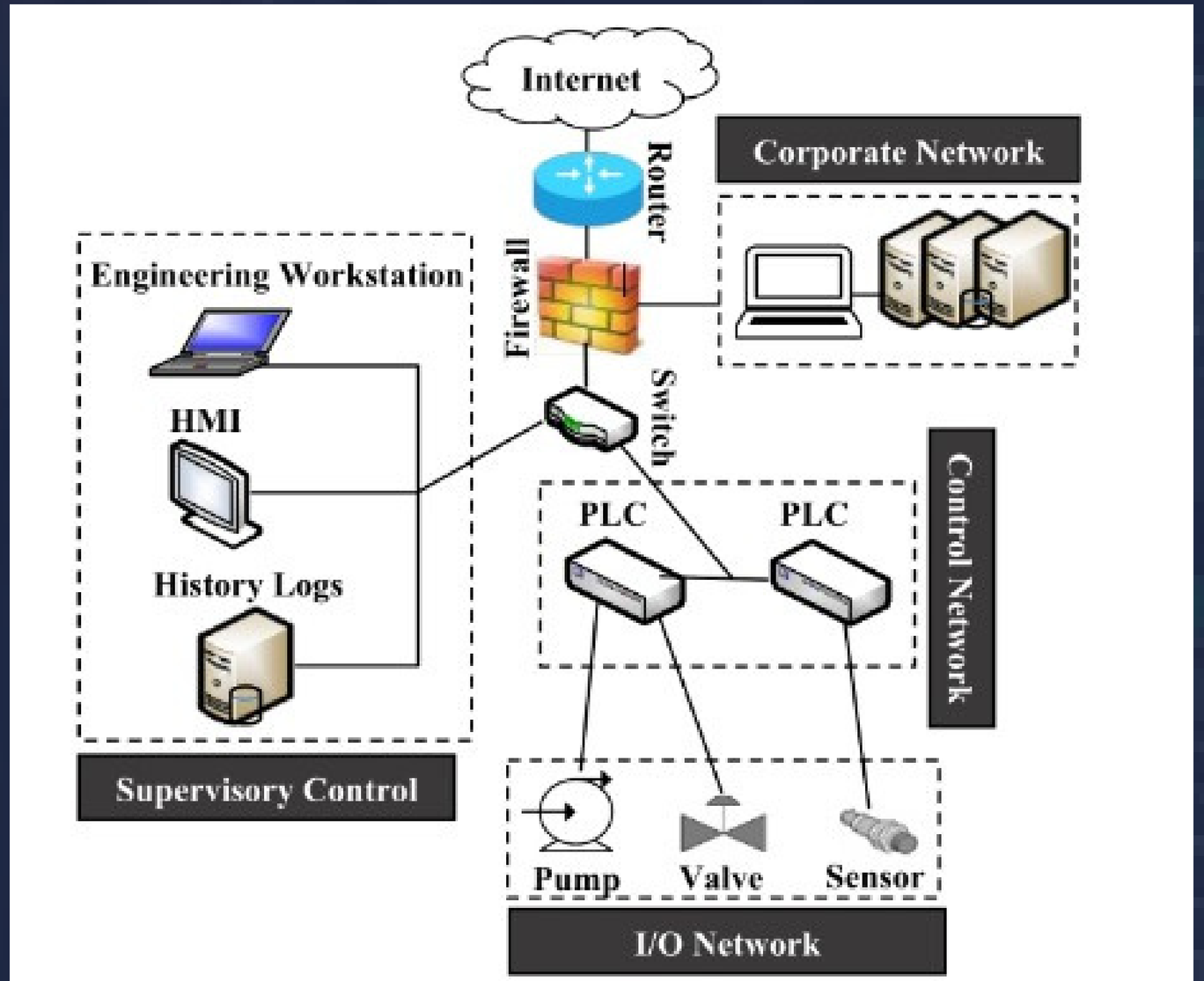
It's main system responsible for securing, controlling and monitoring the IIoT devices.

Control Network

The Control Network includes programmable logic controllers(PLCs) that directly sense and manages data. It collect the data and sends command to actuators.

Corporate Network

It consists of servers, computer and other others connected to the network for other general services such as file transfer, website hosting ,planning etc


Internet
Router
Corporate Network
Firewall
Engineering Workstation
HMI
History Logs
Switch
PLC
PLC
Control Network
Supervisory Control
Pump
Valve
Sensor
I/O Network

Whats the Problem ?

In the past, these systems were isolated making them unsusceptible to external malicious attacks.
With the convergence of IT with OT that is increased connectivity of ICS with corporate network has broughts this systems to a risky position.

Whats the Problem ?

Due to the sensitive nature of many industrial applications, security has become the primary concern.
More specifically lack of security considerations in there communication protocols.

Communication protocols

There are several data transmission protocols in the SCADA systems. Most of them have been designed without accounting for cyber risks or security mechanisms to counter them

Communication protocols

The Key protocols involved are :

- **MODBUS**
- **DNP3**
- **BACnet**
- **MQTT**

All of them lack encryption and security against malicious attacks.

THE LANGUAGE OF CONTROL IS UNSECURED

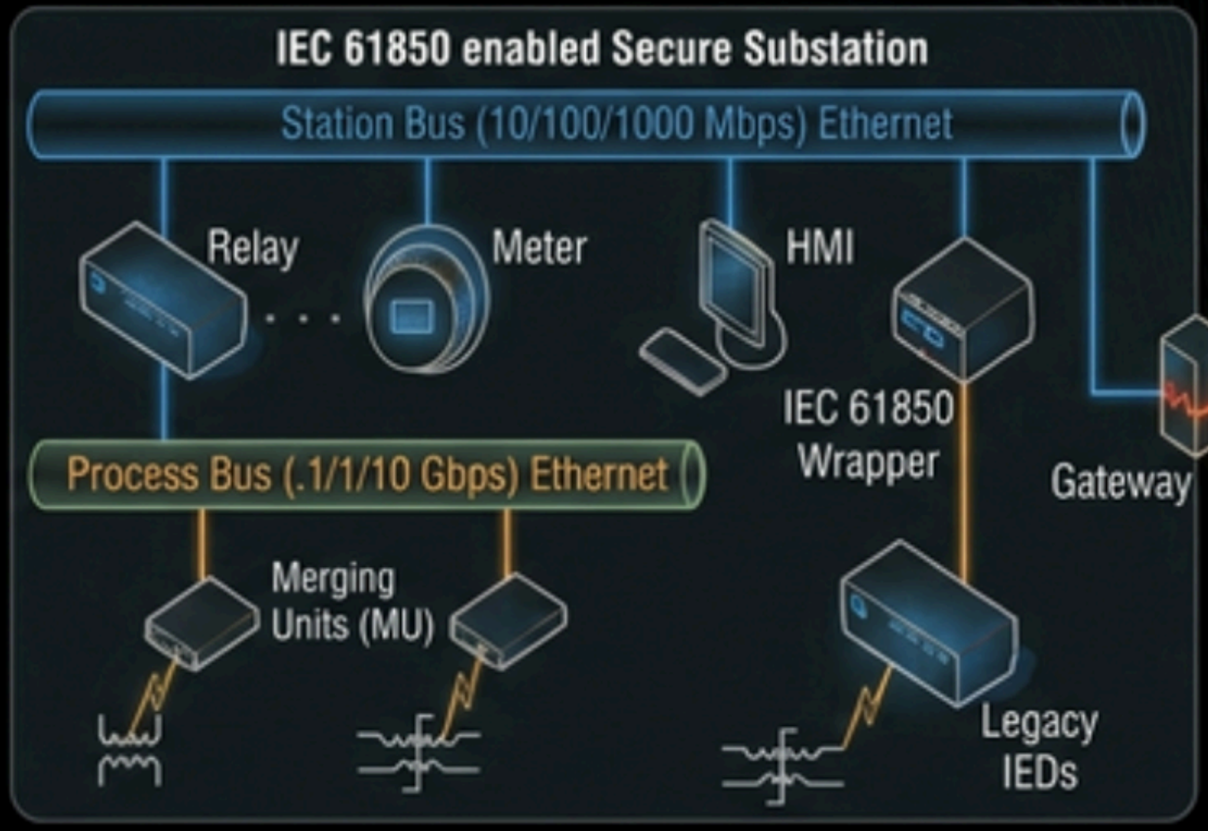
DNP3

IEC 61850

MODBUS

IEC 104

NO NATIVE ENCRYPTION
NO AUTHENTICATION



Built for speed (milliseconds).
Not built for secrecy.

Notebookl

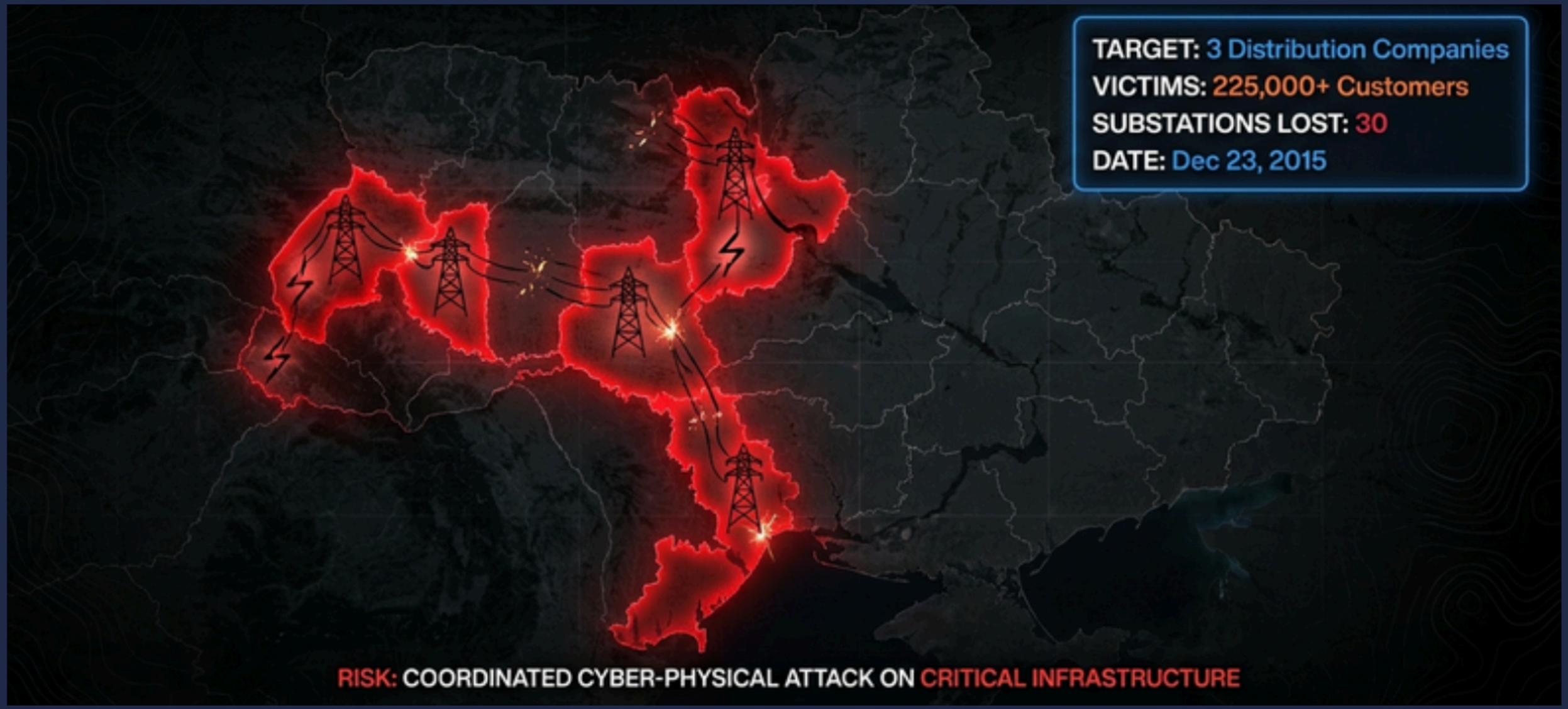
The Security Paradox highlights the tension between reliability and security in SCADA design.

Key points include:

Legacy Vulnerability: Many SCADA systems lack essential security measures, making them susceptible to attacks, as seen in the 2015 Ukraine cyberattack.

Convergence Risk: Integration with IT networks, Cloud platforms, and IoT devices exposes SCADA systems to new vulnerabilities, like malware and phishing, which legacy protocols cannot handle.

Analysis of Ukraine
Cyber Attack


TARGET: 3 Distribution Companies
VICTIMS: 225,000+ Customers
SUBSTATIONS LOST: 30
DATE: Dec 23, 2015
RISK: COORDINATED CYBER-PHYSICAL ATTACK ON CRITICAL INFRASTRUCTURE

In this attack power failure was last step.
30 substations (7 110kv substations and 23 35kv substations) were switched off, and about 230,000 people were without electricity for a period from 1 to 6 hours

ANATOMY OF A BREAKDOWN: THE KILL CHAIN

INFILTRATION
Spear Phishing /
Excel Macro

SPRING 2015

RECONNAISSANCE
Lateral Movement / Network
Scanning / Firmware Mapping

SUMMER/FALL 2015

EXECUTION
HMI Hijacking /
Remote Breaker Open

DEC 23, 2015

How was attack done ??

Spear-Phishing Entry
Targeted emails compromise corporate network

↓

BlackEnergy Malware Installed
Persistent backdoor access gained

↓

SCADA System Compromised
Industrial control systems seized

↓

Remote Shutdown of Substations
Electric supply manually switched off

↓

IT Infrastructure Disabled
UPS, modems, RTUs destroyed

↓

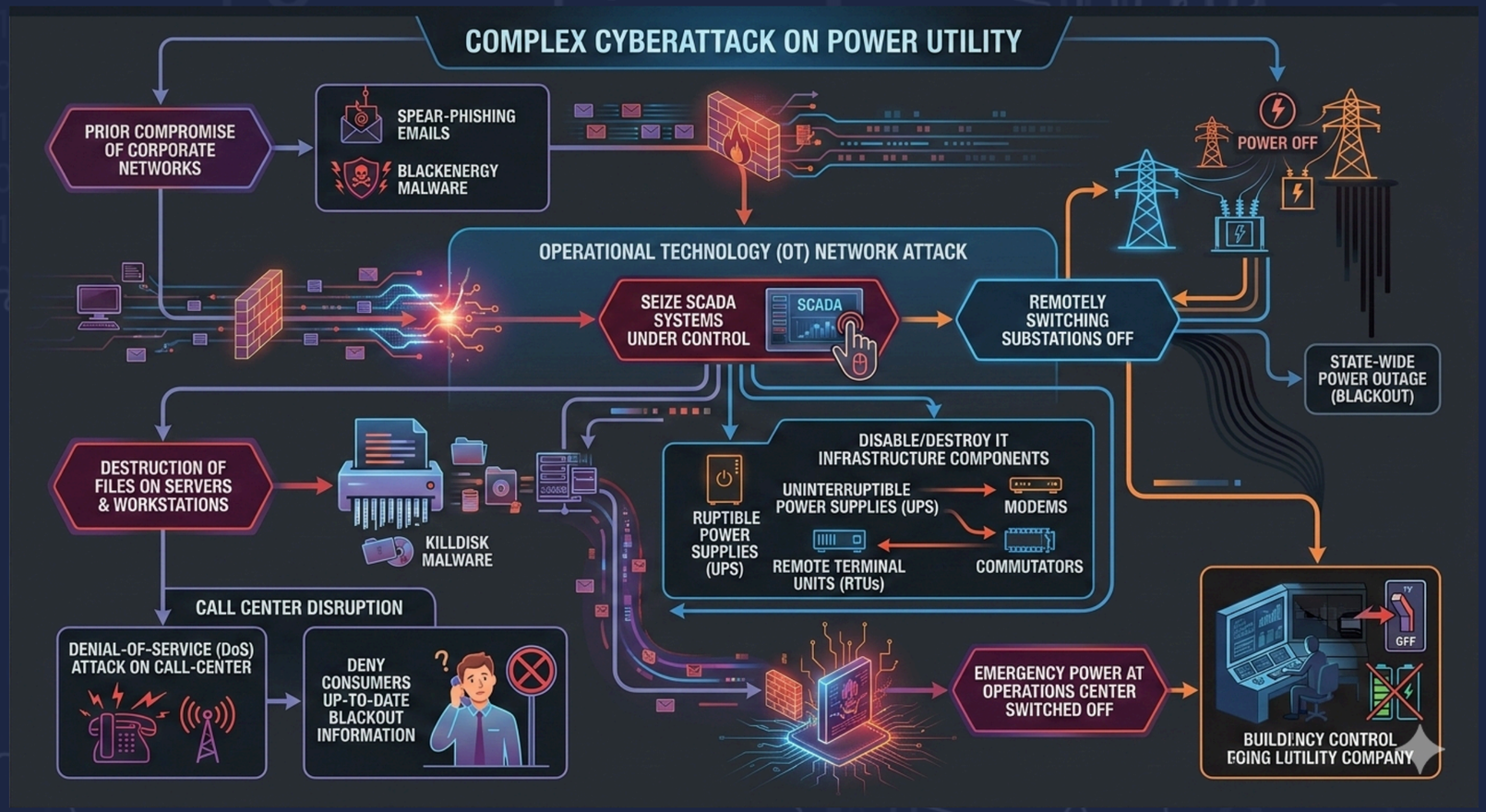
KillDisk Malware Activated
Critical files erased from servers

↓

Call Center DoS Attack
Consumers denied outage information

↓

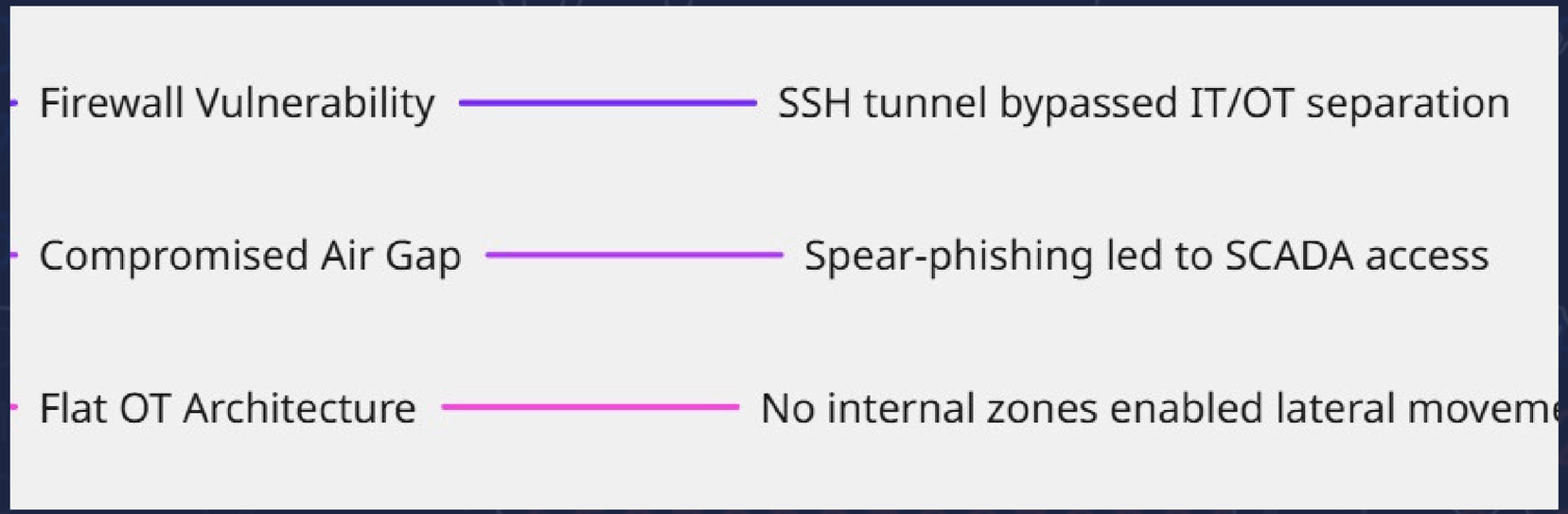
Emergency Power Switched Off
Operations center backup disabled



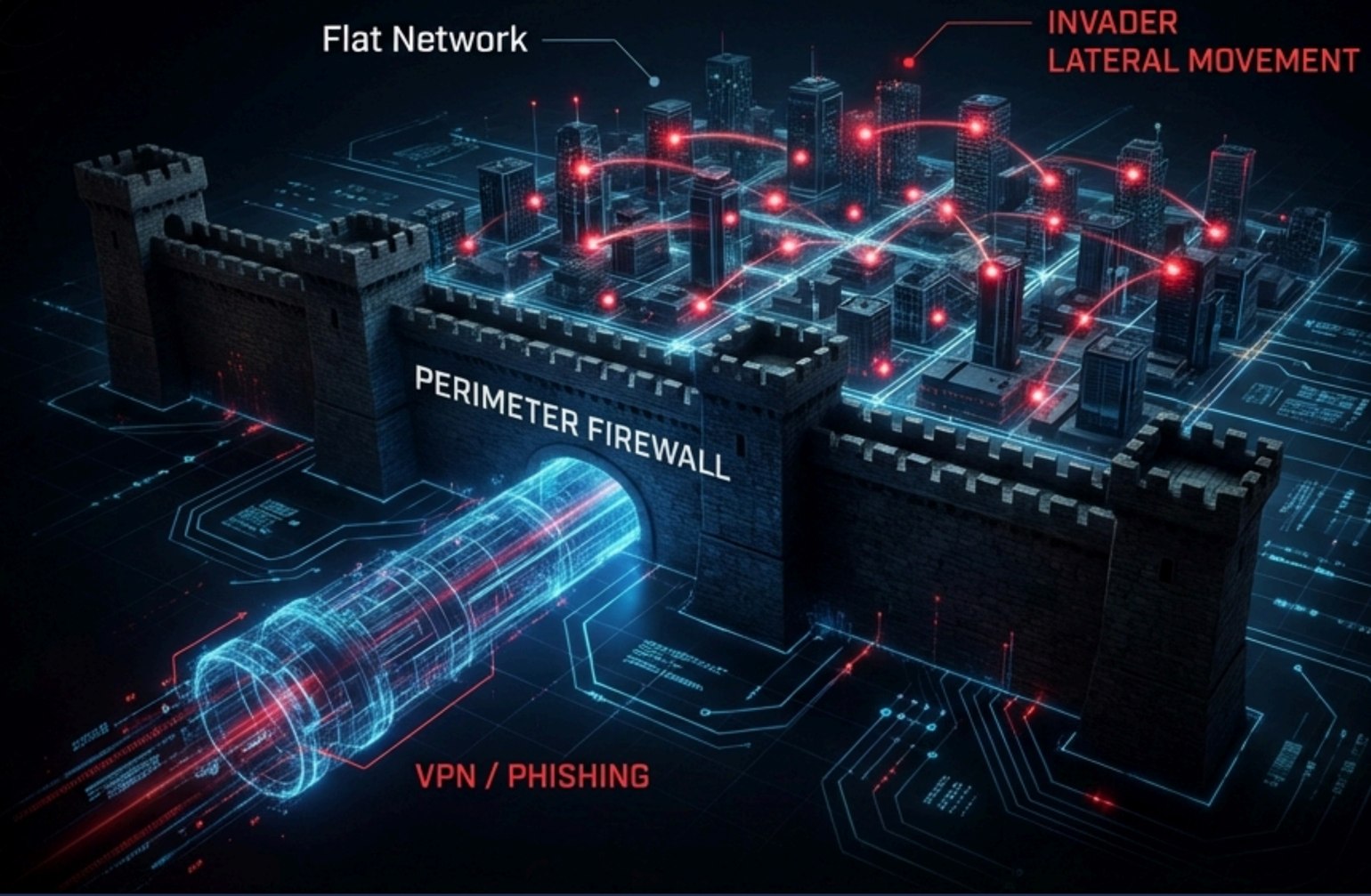
This incident demonstrates that reliance on perimeter security and security through obscurity is fundamentally inadequate against Advanced Persistent Threats (APTs). The attack kinematics highlight specific failures in Network Segmentation (IEC 62443 FR5), Intrusion Detection (IEC 62443 FR6), and Device Integrity.

WHY FR5 AND FR6 Structure failed ?

The Ukraine attack highlights the failure of perimeter-based segmentation in cybersecurity, emphasizing the fragility of static rules over dynamic trust. Key points include:



THE FAILURE OF IMPLICIT TRUST



The Problem:
Once you are inside, you are trusted. Legacy protocols do not verify identity.

The incident highlights failures in detection and visibility, particularly Breach Dwell Time and Foundational Requirement 6 (Timely Response to Events)

- Silent Reconnaissance: The attack spanned six to eight months, utilizing BlackEnergy 3 malware for network reconnaissance and credential harvesting.
- Lack of OT Telemetry: The utility lacked an Intrusion Detection System (IDS) for OT traffic, causing attackers' activities to go unnoticed amidst normal network traffic.
- Weak Authentication and Access Control: The attack exploited SCADA systems with single-factor authentication, allowing stolen credentials to facilitate the attack.
- The absence of Multi-Factor Authentication (MFA) and local approval for remote connections enabled attackers to bypass security protocols, allowing silent access.

The attack on legacy SCADA protocols exposed significant vulnerabilities, including:

HMI Hijacking: Attackers remotely controlled the Human-Machine Interface (HMI) to open circuit breakers without requiring re-authentication or safety checks, indicating a failure in application security.
Firmware Bricking: Attackers inserted malicious code into the firmware of Ethernet-to-Serial gateways, making them unrecoverable. This underscores a failure in Device Integrity, as the devices accepted unsigned firmware updates without cryptographic verification, a common shortfall in legacy industrial hardware.

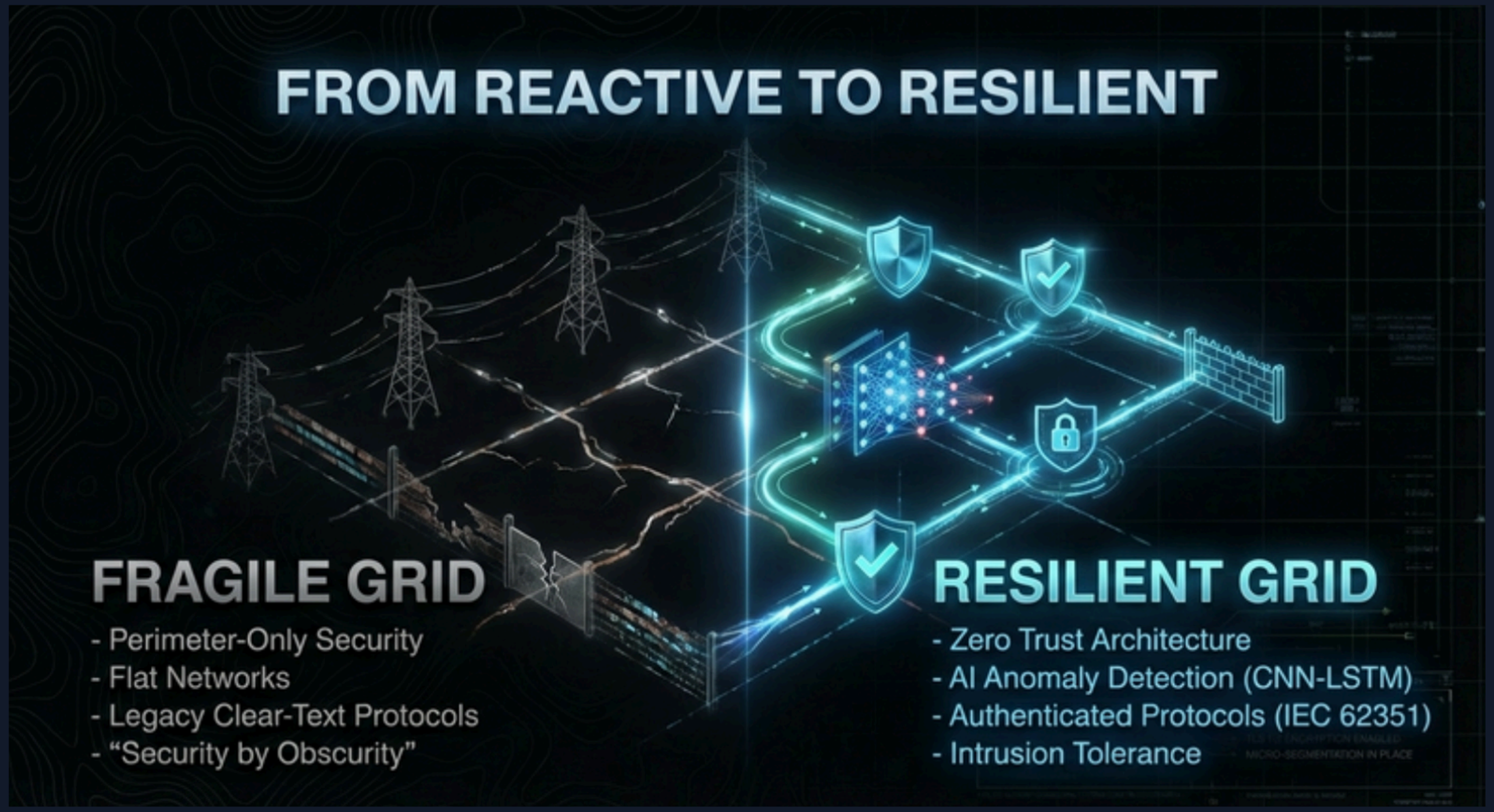
FAILURE CATEGORY	FAILURE DESCRIPTION	RECOMMENDED SOLUTION
Segmentation	Attackers pivoted via a single SSH tunnel; flat OT network allowed lateral spread.	Failure of IEC 62443 Zones & Conduits; Need for Zero Trust Micro-segmentation
Detection	6+ months of undetected reconnaissance using BlackEnergy malware.	Lack of Anomaly-Based IDS (e.g., CNN-LSTM models) to flag behavioral deviations.
Authentication	Valid credentials used for lateral movement; no MFA or local approval.	Weak Identity Management; Failure of Defense-in-Depth.
Resilience	Gateways "bricked" via firmware; HMI used against itself.	Lack of Code Signing/Remote Attestation and physics-aware command validation.

Activate Windows
Go to Settings to activate Windows.

How can we solve the problem?

Threat Vector	Legacy Approach (Failed)	Future Technology/Countermeasure
Lateral Movement	Firewalls & Air Gaps	**Zero Trust Micro-segmentation** (Identity-based, not IP-based) [20].
Protocol Abuse	Trusting DNP3/Modbus	**IEC 62351** (Encryption/Auth) & **Physics-Aware IDS** [21].
Unknown Attacks	Signature-based IDS	**Hybrid CNN-LSTM** (Spatio-Temporal Anomaly Detection) [22].
Firmware Attacks	Unverified Updates	**Remote Attestation** & Static Kernels [19].
Breach Response	Manual intervention	**Automated Policy Enforcement** (PDP/PEP) reducing dwell time to <2 mins [8].

What did we learned?



What did we learned?

References

Research & Conference Proceedings

- **Alsaiari, A., & Ilyas, M. (2025) :**

A Hybrid CNN-LSTM Deep Learning Model for Intrusion Detection in Smart Grid. International Journal of Artificial Intelligence and Applications (IJAIA), 16(5), 1-22. DOI: 10.5121/ijaia.2025.16501.

- **Sudha Gupta, Faruk Kazi, Sushama Wagh, Ruta Kambli :**

Neural Network Based Early Warning System for an Emerging Blackout in Smart Grid Power Networks

- **Nelson, O. C., Osoko, E. A., & Ologunbaba, T. (2023):**

Designing a zero-trust cybersecurity architecture for smart grid communication systems to safeguard critical energy infrastructure. International Journal of Science and Research Archive, 10(02), 1335-1348. DOI: 10.30574/ijsra.2023.10.2.1061.

References

Research & Conference Proceedings

- **Sridhar, S., Hahn, A., & Govindarasu, M. (2011):**

Cyber–Physical System Security for the Electric Power Grid. Proceedings of the IEEE. DOI: 10.1109/JPROC.2011.2165269.

- **Zolanvari, Teixeria, Lav Gupta , Khaled Khan ,Raj Jain.**

Machine Learning Based Vulnerability Analysis of Industrial Internet of Things.

References

Technical Standards & Agency Reports

- **Pillitteri, V. Y., & Brewer, T. L. (2014) :**

Guidelines for Smart Grid Cybersecurity. NIST Interagency/Internal Report (NISTIR) 7628 Rev 1. National Institute of Standards and Technology. DOI: 10.6028/NIST.IR.7628r1.

- **International Electrotechnical Commission (IEC). IEC 62443:**

Industrial communication networks - Network and system security. As summarized in Wikipedia, The Free Encyclopedia.

References

Forensic Analyses & Industry Intelligence

- **Bock, P., Hauet, J.-P., Foley, R., & Françoise, R. (2017) :**

Special Section: Ukrainian power grids cyberattack: A forensic analysis based on ISA/IEC 62443. ISA InTech Magazine.

- **Williamson, G. (2015) :**

OT, ICS, SCADA – What’s the difference?

- **Darktrace.**

Cybersecurity for Electric Power | Best Practices and Risks. Darktrace Glossary.

Presented by Aditya Salunke